DRAWBRIDGE

XYZ CAPITAL

CHATGPT SECURITY CONTROLS REVIEW

[DATE]

SAMPLE

TABLE OF CONTENTS

OVERVIEW 2
THE VALUE OF PERFORMING A CHATGPT ASSESSMENT 2

RISK ASSESSMENT APPROACH 2

SCOPE 3

RISK RATINGS 3

RISK ASSESSMENT FINDINGS 4
SUMMARY 4
RISKS IDENTIFIED 4

OVERVIEW

XYZ Capital ("**XYZ Capital**" or the "**Firm**") has engaged Drawbridge Partners, LLC ("**Drawbridge**") to assess the security controls and configurations in place within the Firm's ChatGPT environment. This assessment will detail existing risks within XYZ Capital's ChatGPT environment, while providing recommendations to enhance the Firm's cybersecurity posture.

THE VALUE OF PERFORMING A CHATGPT ASSESSMENT

Performing a ChatGPT Assessment helps organizations identify cyber security risks that can leave them vulnerable to compromise of critical systems and data. By evaluating the strength of their existing cybersecurity controls, Drawbridge can help reduce risk exposure and prioritize remediation efforts.

Performing a ChatGPT Assessment allows a firm to:

- Identify misconfigured or missing security controls within the ChatGPT environment
- Evaluate the effectiveness of existing security controls
- Implement controls to safeguard confidential data and the systems in which that data is processed, stored, or transmitted
- Safeguard organizations from potential cyber threats which may lead to financial losses
- Reduce cyber-risk
- Meet investor/regulatory requirements

RISK ASSESSMENT APPROACH

Drawbridge's risk assessment approach aligns with the Center for Internet Security standards ("CIS") security controls framework as well as other industry standard frameworks. Drawbridge requested that XYZ Capital provide access to the Firm's ChatGPT environment via screenshare. Drawbridge worked with the organization to assess the environment and identify various risks and strengths within the existing configuration.

The identified risks were assigned a rating to communicate both severity and the order in which each risk should be addressed. The rating criteria is based on the probability of a risk being exploited and the severity of impact that each exploited risk would have on the organization. In addition to risk ratings, recommendations for mitigating or remediating the risks are available for guidance.

SCOPE

For the purposes of the assessment, "confidential data" means any non-public data that could adversely affect XYZ Capital if it were made available to the public. Confidential data includes, but is not limited to:

- Employee or prospective employee data
- Business data
- Investor or prospective investor data
- Client or prospective client data
- Investment data such as, but not limited to:
    - Personally identifiable information, intellectual property, electronic communications, financial records, legal documentation, any data not available to the public, or any other data deemed confidential by XYZ Capital.

RISK RATINGS

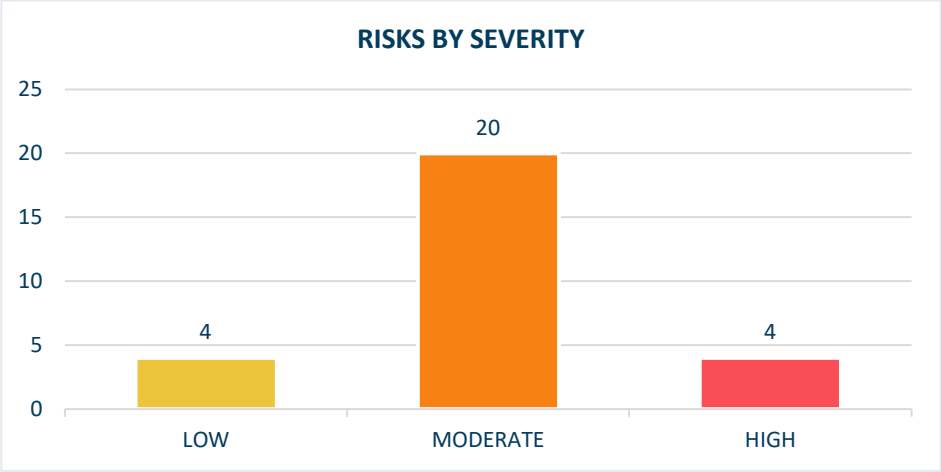
The rating criteria is based on the probability of an incident occurring and the severity of impact the incident would have if the risks were to materialize.

HIGH	High-severity risks are risks that: • Have a high likelihood of causing significant harm to the organization's operations, financial stability, or reputation; • Should be prioritized for remediation, and swift action to mitigate is recommended due to the high likelihood of exploitation; • Exploitation may lead to significant data breaches, widespread systems disruptions, or sizeable financial loss.
MODERATE	Moderate-severity risks are those that: • Could negatively impact the organization but may not pose an immediate threat; • Have a moderate likelihood of occurrence and/or would result in a moderate level of disruption; • Should be addressed in a timely manner to avoid escalation to a higher level of risk, though they should not be prioritized over high-severity findings; • Often include issues that could disrupt non-critical operations.
LOW	Low-severity risks are those that: • Have a minimal impact on the organization if exploited and are often accepted or monitored with minimal mitigation action; • Have a low likelihood of being exploited and/or would lead to minor disruptions; • While not urgent, should be tracked to ensure they do not escalate over time; • Compensating controls often lead to the acceptance of low severity risks, though it is recommended that they be revisited each time an assessment is performed.

RISK ASSESSMENT FINDINGS

SUMMARY

The graph below displays the breakdown of High, Moderate, and Low severity risks Drawbridge identified during the assessment. In addition to risk ratings, recommendations for mitigating or remediating the risks are available for guidance.



RISKS IDENTIFIED

IDENTITY & ACCESS MANAGEMENT			
Severity	**Findings**	**Risk**	**Recommendation**
HIGH	Single Sign-On (SSO) is not configured.	Without SSO, user access may persist after termination, credentials may be weak or reused, and access cannot be centrally revoked. This significantly increases the risk of unauthorized access to sensitive prompts, files, and GPT configurations.	Enforce SSO for all users through the corporate IdP and disable local ChatGPT passwords. Validate that all active users are federated identities.
MODERATE	SCIM is not used to provision and deprovision user accounts.	Manual user management can result in orphaned accounts, delayed deprovisioning, and inconsistent role assignments. Former employees retaining access pose a significant insider risk.	Enable SCIM provisioning and validate that user lifecycle events are automatically reflected in ChatGPT. Periodically reconcile users against HR records.
Security Controls Currently in Place			
• Role-Based Access Control (RBAC) is in use. • Administrative access is limited to two to three accounts.			

PLATFORM SECURITY			
Severity	**Findings**	**Risk**	**Recommendation**
HIGH	Users can share screen or video while using Voice.	Enabling screen or video sharing can expose sensitive information displayed on a user's screen, such as internal systems, customer data, or credentials, without proper safeguards. This increases the risk of accidental data leakage during live interactions.	Disable this feature by default or restrict to approved teams.
LOW	Web Search is enabled.	Web access may introduce untrusted data sources or risk accidental data disclosure.	Disable web search unless explicitly required.
Security Controls Currently in Place			
• External domain invites are not allowed.			

PERMISSIONS & ROLES			
Severity	**Findings**	**Risk**	**Recommendation**
MODERATE	Codex Local Usage Control is enabled.	Local execution may bypass centralized logging and security monitoring, increasing data leakage risk. Sensitive code or data could be processed outside approved environments.	Disable Codex Local unless a clear business need exists. Restrict usage to approved developer roles.
MODERATE	Codex CLI Device Code Authentication is not enabled.	Weak or inconsistent authentication may allow unauthorized CLI access. This increases the risk of credential misuse and unauthorized code access.	Require device code authentication for all Codex CLI users. Validate alignment with enterprise authentication standards. Benefits of implementing this are: - No passwords are entered into the CLI (reduces credential theft risk) - Authentication is completed in the user's browser via the enterprise IdP - Tokens are scoped, time-limited, and revocable -MFA and conditional access policies enforced by the IdP still apply
Security Controls Currently in Place			
• ChatGPT cannot reference past notes and transcripts. • Additional Models Enablement is disabled.			

CODEX SECURITY			
Severity	**Findings**	**Risk**	**Recommendation**
MODERATE	Codex Cloud usage is enabled.	Cloud-based code processing may introduce external data handling risks if not governed. Unrestricted access may lead to inappropriate code or data exposure.	Restrict Codex Cloud usage to approved users and use cases. Review usage periodically.
Security Controls Currently in Place			
• Slack App Posting is not enabled.			

GPT SECURITY			
Severity	**Findings**	**Risk**	**Recommendation**
HIGH	Users can use GPTs created outside of your workspace.	If users can access and use GPTs created outside of the organization's workspace, they may interact with tools that have unvetted prompts, external API connections, or unknown data handling practices. This increases the risk of sensitive information being shared with third parties, exposure to insecure integrations, and reduced visibility into how data is processed or stored.	Restrict users to GPTs that are created and approved within the organization's workspace, and implement a formal review process to evaluate external GPTs for data handling, integrations, and security risks before allowing their use.
HIGH	Public GPT Sharing is enabled.	Public sharing may expose internal logic, prompts, or proprietary workflows.	Disable public GPT sharing globally.
MODERATE	GPT builders can enable apps.	Apps may introduce external data flows without oversight, leading to data leakage.	Restrict app enablement to approved builders only.
Security Controls Currently in Place			
• An approved app allowlist is in place.			

POLICY & PROCESS			
Severity	**Findings**	**Risk**	**Recommendation**
HIGH	Tabletop Exercises do not include AI-related incidents.	Teams may be unprepared to respond effectively to AI-related incidents, which will increase the impact of a cyber incident..	Conduct annual tabletop exercises focused on AI misuse scenarios.
Security Controls Currently in Place			
• Connectors are reviewed at least quarterly.			